Projekt stażowy: GDPR-Compliant Web App

GitHub Pages + Azure Database | 160 godzin praktyk | Trójmiejskie technika o profilu programistycznym

Uczeń dostaje **oczekiwany efekt końcowy** (narzędzie do zarządzania danymi osobowymi zgodne z RODO), samodzielnie dobiera technologie i z **wsparciem mentora** dostarcza możliwie najwięcej funkcjonalności. Projekt nawiązuje do strony **GDPR Live Inspector** i jest jej praktycznym rozszerzeniem o trwały backend i pełną implementację praw użytkownika.

Architektura projektu

Frontend	Backend / API	Baza danych	CI/CD
GitHub Pages (HTML/JS/CSS lub React/Vue)	Azure Functions lub Azure Static Web Apps API	Azure SQL lub Cosmos DB (free tier)	GitHub Actions (auto-deploy po push)

Rozwinięcia skrótów użytych w dokumencie:

- ***CRUD*** *— Create, Read, Update, Delete (tworzenie, odczyt, aktualizacja, usuwanie)*
- ***REST API*** *— Representational State Transfer Application Programming Interface (interfejs programistyczny oparty na architekturze REST)*
- ***CI/CD*** *— Continuous Integration / Continuous Delivery (ciągła integracja i ciągłe dostarczanie)*
- ***JWT*** *— JSON Web Token (token uwierzytelniający w formacie JSON)*
- ***RBAC*** *— Role-Based Access Control (kontrola dostępu oparta na rolach)*
- ***OWASP*** *— Open Web Application Security Project (otwarty projekt bezpieczeństwa aplikacji webowych)*
- ***XSS*** *— Cross-Site Scripting (wstrzykiwanie złośliwych skryptów między stronami)*
- ***CSRF*** *— Cross-Site Request Forgery (fałszerstwo żądań między stronami)*
- ***SQL Injection*** *— atak polegający na wstrzyknięciu złośliwego kodu SQL do zapytania bazodanowego*
- ***CORS*** *— Cross-Origin Resource Sharing (współdzielenie zasobów między różnymi domenami)*
- ***CSP*** *— Content Security Policy (polityka bezpieczeństwa treści)*
- ***HSTS*** *— HTTP Strict Transport Security (wymuszenie bezpiecznego połączenia HTTPS)*
- ***TLS*** *— Transport Layer Security (protokół szyfrowania transmisji danych)*
- ***TDE*** *— Transparent Data Encryption (przezroczyste szyfrowanie danych w spoczynku — wbudowane w Azure SQL)*
- ***ORM*** *— Object-Relational Mapping (mapowanie obiektowo-relacyjne — biblioteka do obsługi bazy danych bez pisania surowego SQL)*

- ***UUID*** *— Universally Unique Identifier (globalnie unikalny identyfikator — zastępuje prawdziwe dane w pseudonimizacji)*
- ***RODO*** *— Rozporządzenie Ogólne o Ochronie Danych (po angielsku: GDPR — General Data Protection Regulation)*
- ***GDPR*** *— General Data Protection Regulation (po polsku: RODO)*
- ***README*** *— Read Me (plik tekstowy z opisem projektu, zwyczajowo umieszczany w repozytorium)*
- ***DevSecOps*** *— Development, Security, Operations (podejście łączące programowanie, bezpieczeństwo i operacje IT)*

Harmonogram 160 godzin

Etap	Czas	Zakres	Efekt końcowy
1. Setup + Create, Read, Update, Delete	~40h	Środowisko, baza, formularze, interfejs API	Działająca aplikacja z dodawaniem, edycją i usuwaniem
2. Bezpieczeństwo	~35h	Uwierzytelnianie, walidacja, zabezpieczenia	Bezpieczny login, ochrona przed atakami
3. RODO / GDPR	~45h	Prawa użytkownika, zgody, logi	Pełna zgodność z RODO (Art. 15–21)
4. UX + dokumentacja	~20h	Panel użytkownika, README, instrukcje	Gotowy projekt do portfolio
5. Prezentacja	~20h	Testy, przegląd kodu, demo	Publiczne repozytorium + live demo

---

MODUŁ 1 — Podstawowa aplikacja Create, Read, Update, Delete (~40h)

Łącznie w module: 17 funkcjonalności

1.1 Środowisko i infrastruktura (~8h)

1. Repozytorium GitHub z podziałem na /frontend i /backend
2. GitHub Actions: automatyczny deploy na GitHub Pages po wypchnięciu kodu do gałęzi main (Continuous Integration / Continuous Delivery)
3. Azure Static Web Apps lub Azure Functions (wyzwalacz HTTP) jako backend — interfejs programistyczny REST
4. Azure SQL Database lub Cosmos DB (darmowy poziom / subskrypcja studencka)
5. Zmienne środowiskowe w GitHub Secrets — brak haseł i kluczy w kodzie źródłowym

1.2 Formularze i operacje Create, Read, Update, Delete (~20h)

1. Formularz dodawania rekordu danych osobowych (imię, email, telefon, cel przetwarzania)
2. Formularz edycji istniejącego rekordu z walidacją po stronie klienta (przeglądarki)
3. Przycisk usunięcia rekordu z potwierdzeniem (okno modalne / dialog)
4. Lista rekordów z paginacją (10 / 25 / 50 rekordów na stronę)
5. Wyszukiwanie i filtrowanie rekordów po wybranym polu lub wartości
6. Eksportowanie widocznych danych do pliku CSV — Comma-Separated Values (wartości rozdzielone przecinkami) *(RODO Art. 20 — prawo do przenoszalności)*

1.3 Interfejs programistyczny REST (backend) (~12h)

1. GET /records — lista rekordów z paginacją i filtrowaniem
2. POST /records — dodanie nowego rekordu (walidacja po stronie serwera)
3. PUT /records/{id} — edycja rekordu o podanym identyfikatorze
4. DELETE /records/{id} — usunięcie rekordu o podanym identyfikatorze
5. GET /records/{id}/export — eksport danych użytkownika w formacie JSON (JavaScript Object Notation) lub CSV *(RODO Art. 20)*
6. Obsługa błędów HTTP (400 Błędne żądanie, 401 Brak autoryzacji, 403 Zakaz dostępu, 404 Nie znaleziono, 500 Błąd serwera) bez ujawniania szczegółów stosu wywołań

MODUŁ 2 — Bezpieczeństwo aplikacji webowej (~35h)

Łącznie w module: 18 funkcjonalności

2.1 Uwierzytelnianie i autoryzacja (~12h)

1. Rejestracja i logowanie użytkownika z tokenami JWT (JSON Web Token — token uwierzytelniający w formacie JSON)
2. Haszowanie haseł po stronie serwera algorytmem bcrypt — nigdy przechowywanie haseł jako zwykłego tekstu
3. Kontrola dostępu oparta na rolach (RBAC — Role-Based Access Control): administrator / zwykły użytkownik / analityk
4. Wylogowanie z unieważnieniem tokenu (lista zablokowanych tokenów lub tokeny krótkoterminowe)
5. Blokada konta po N nieudanych próbach logowania (ochrona przed atakiem brute-force — metodą siłową)
6. Token odświeżający (refresh token) z bezpiecznym przechowywaniem w ciasteczku HttpOnly (niedostępnym dla JavaScript)

2.2 Ochrona przed atakami według listy Open Web Application Security Project Top 10 (~15h)

1. Zapytania parametryzowane i mapowanie obiektowo-relacyjne (ORM) — ochrona przed wstrzykiwaniem kodu SQL (SQL Injection, kategoria A03 według OWASP)
2. Kodowanie znaków specjalnych w wyjściu i oczyszczanie kodu HTML — ochrona przed wstrzykiwaniem skryptów między stronami (XSS — Cross-Site Scripting, kategoria A03)
3. Token CSRF (Cross-Site Request Forgery — fałszerstwo żądań między stronami) dla wszystkich formularzy modyfikujących dane (kategoria A01)
4. Walidacja każdego pola formularza po stronie serwera: typ, maksymalna długość, dopuszczalny format
5. Ograniczenie liczby zapytań do interfejsu API (rate limiting — maks. N zapytań na minutę z jednego adresu IP)
6. Nagłówki bezpieczeństwa HTTP: CSP (Content Security Policy — polityka bezpieczeństwa treści), HSTS (HTTP Strict Transport Security — wymuszenie HTTPS), X-Frame-Options (ochrona przed osadzaniem w ramce), X-Content-Type-Options (ochrona przed zgadywaniem typu pliku)
7. Współdzielenie zasobów między domenami (CORS — Cross-Origin Resource Sharing) skonfigurowane wyłącznie dla dozwolonych domen

2.3 Bezpieczeństwo danych (~8h)

1. Szyfrowanie danych w spoczynku: Azure Transparent Data Encryption (TDE — przezroczyste szyfrowanie danych wbudowane w Azure SQL)
2. Wymuszenie HTTPS / TLS (Transport Layer Security — protokół szyfrowania transmisji) dla całej komunikacji — realizowane automatycznie przez Azure i GitHub Pages
3. Maskowanie danych wrażliwych w logach serwera — brak numerów PESEL ani adresów email w plikach dziennika
4. Bezpieczne zmienne środowiskowe — żadnych haseł, kluczy ani sekretów w kodzie źródłowym repozytorium
5. Skanowanie zależności bibliotek zewnętrznych przez GitHub Dependabot — wykrywanie znanych podatności bezpieczeństwa (DevSecOps — Development, Security, Operations)

MODUŁ 3 — Zgodność z RODO / GDPR (~45h)

Łącznie w module: 16 funkcjonalności

3.1 Prawa użytkownika (Art. 15–21 RODO) (~20h)

1. **Prawo dostępu (Art. 15 RODO)** — panel „Moje dane": pełny widok wszystkich danych przechowywanych przez system
2. **Prawo do sprostowania (Art. 16 RODO)** — formularz edycji własnych danych osobowych dostępny dla każdego zalogowanego użytkownika

3. **Prawo do usunięcia (Art. 17 RODO)** — „prawo do bycia zapomnianym": opcja trwałego usunięcia konta i wszystkich powiązanych danych
4. **Prawo do przenoszalności danych (Art. 20 RODO)** — eksport własnych danych w formacie JSON i CSV do pobrania przez użytkownika
5. **Prawo do sprzeciwu (Art. 21 RODO)** — formularz zgłoszenia sprzeciwu wobec przetwarzania danych z konkretnym uzasadnieniem
6. **Prawo do ograniczenia przetwarzania (Art. 18 RODO)** — flaga „zamrożenia" przetwarzania rekordu na wniosek użytkownika lub administratora

3.2 Podstawy prawne i zarządzanie zgodami (Art. 6–7 RODO) (~14h)

1. Baner zgody na pliki cookies z trzema kategoriami: niezbędne / analityczne / marketingowe *(Art. 6 RODO)*
2. Oddzielne pola wyboru (checkboxy) dla każdej zgody — jedna zgoda = jeden cel przetwarzania *(Art. 7 RODO — granularność zgód)*
3. Historia udzielonych i wycofanych zgód z dokładną datą i godziną każdej zmiany (dziennik zgód)
4. Widoczne oznaczenie pól formularza jako: WYMAGANE / OPCJONALNE / NADMIAROWE — zasada minimalizacji danych
5. Informacja o celu zbierania każdego pola formularza (podpowiedź lub podpis pod polem) *(Art. 13 RODO)*
6. Strona polityki prywatności z pełnymi klauzulami informacyjnymi *(Art. 13–14 RODO)*

3.3 Pseudonimizacja i maskowanie (Art. 32 RODO) (~11h)

1. Pseudonimizacja: generowanie globalnie unikalnego identyfikatora UUID (Universally Unique Identifier) jako identyfikatora rekordu zamiast prawdziwych danych osobowych *(Art. 32 RODO)*
2. Maskowanie danych w zależności od roli: administrator widzi pełne dane, pracownik wsparcia widzi tylko częściowe dane
3. Tabela kluczy pseudonimizacji przechowywana w oddzielnej kolekcji / tabeli, odizolowanej od głównych danych
4. Anonimizacja danych do celów analitycznych — generalizacja wartości (np. wiek → przedział wiekowy)

MODUŁ 4 — Panel użytkownika, dziennik zdarzeń i dokumentacja (~20h)

Łącznie w module: 10 funkcjonalności

4.1 Dziennik zdarzeń (Audit Log) i monitoring (~10h)

1. Dziennik zdarzeń: rejestracja kto, kiedy i co zrobił z danymi (operacje INSERT, UPDATE, DELETE) *(Art. 5 ust. 2 RODO — zasada rozliczalności)*

2. Dziennik dostępu do danych: każde pobranie rekordu zapisane z datownikiem (timestamp) i rolą użytkownika *(Art. 32 RODO)*
3. Panel administratora z podglądem dziennika — filtrowanie po dacie, użytkowniku i rodzaju akcji
4. Automatyczne usuwanie danych po upływie okresu retencji (np. 2 lata) — zasada ograniczenia przechowywania *(Art. 5 ust. 1 lit. e RODO)*
5. Powiadomienie email do użytkownika po usunięciu jego danych z systemu

4.2 Panel aplikacji i dokumentacja (~10h)

1. Panel użytkownika: moje dane, moje zgody, historia wniosków związanych z RODO
2. Panel administratora: lista użytkowników, status przetwarzań, podgląd dziennika zdarzeń
3. Plik README.md z opisem architektury systemu, instrukcją instalacji i linkiem do działającego demo
4. Dokumentacja interfejsu API w formacie Swagger / OpenAPI lub jako prosta strona HTML
5. Raport RODO generowany do pliku PDF na żądanie — zawiera listę praw i opis ich realizacji w systemie

---

Podsumowanie — łączna liczba funkcjonalności

Moduł	**Liczba funkcjonalności**
Moduł 1 — Podstawowa aplikacja Create, Read, Update, Delete	17
Moduł 2 — Bezpieczeństwo aplikacji webowej	18
Moduł 3 — Zgodność z RODO	16
Moduł 4 — Panel, dziennik zdarzeń, dokumentacja	10
ŁĄCZNIE	**61**

Umiejętności zdobyte przez ucznia

Obszar	**Konkretne umiejętności**
Frontend	HTML/CSS/JavaScript, formularze, walidacja po stronie klienta, komunikacja z interfejsem REST API (fetch/axios)
Backend / Cloud	Azure Functions, interfejs REST API, tokeny JWT, haszowanie haseł, CORS, ograniczenie liczby zapytań (rate limiting)

Baza danych	SQL/NoSQL na Azure, zapytania parametryzowane, mapowanie obiektowo-relacyjne (ORM), schemat, migracje
DevOps / Ciągła integracja i dostarczanie	GitHub Actions, GitHub Secrets, automatyczny deploy, Dependabot
Bezpieczeństwo	Lista OWASP Top 10 w praktyce: XSS, CSRF, SQL Injection, nagłówki HTTP, szyfrowanie
RODO / GDPR	Prawa użytkownika Art. 15–21, zarządzanie zgodami, pseudonimizacja, dziennik zdarzeń, polityka prywatności
Umiejętności miękkie	Czytanie dokumentacji technicznej, przegląd kodu z mentorem, przepływ pracy z Git, pisanie README